

1.5 Information Security Strategy Development

- Defines the plan for achieving **acceptable risk** levels
- Based on governance **principles** established in Part A
- Strategy guides risk **management** and resource optimization
- Aligns **InfoSec** efforts with enterprise needs
- Supports **holistic** security program implementation



Section 1.5: Information Security Strategy Development, which focuses on translating governance into **actionable plans**. This is where theory becomes practice — where high-level oversight and direction are converted into a **structured roadmap** that drives daily security operations and long-term risk management.

The **goal** of developing an information security strategy is to define **how the enterprise will reach an acceptable level of risk**, while **optimizing resources** and maintaining alignment with overall business objectives. This process draws directly from the governance foundation established earlier in Domain 1.

One of the most critical CISM concepts here is that **governance and management are separate but complementary activities**:

Governance sets the **direction** — the risk appetite, priorities, and overall objectives.

Management builds and executes the **structures and processes** to deliver on that direction.

The **information security strategy** sits at the interface of these two areas. It is both **derived from governance** and a **blueprint for management**.

For the information security manager, the strategy becomes a tool to:

Translate executive goals into tactical plans,

Define **risk tolerance** and **risk treatment plans** (as described in Chapter 2),
And deploy a **comprehensive security program** (as covered in Chapter 3).

An effective strategy includes identifying:

Security domains and controls necessary to protect enterprise assets,

The **resource requirements** (financial, technical, human),

And **metrics** to track performance and effectiveness.

Risk optimization plays a central role. It's not about eliminating all risk — that's impractical and expensive. Instead, the strategy should aim to **balance the cost of controls** against the **impact of potential incidents**. This requires input from business units, IT, legal, compliance, and HR.

Another key factor is that the strategy must be **holistic**. It must not only consider technical safeguards like firewalls and encryption but also:

People and culture,

Policies and procedures,

Third-party risk,

And legal obligations.

Importantly, the CISM exam will expect candidates to understand **how to build and justify a strategy** based on:

Threat landscape analysis,

Enterprise priorities,

And cost-benefit trade-offs.

In real-world practice, this means proposing initiatives like incident response enhancements, security awareness programs, or new GRC tools — and tying them directly to risk reduction and business goals.

1.5.1 Business Goals and Objectives

- **Strategy = Plan** to achieve business objectives
- Information security governance is a subset of **corporate governance**
- Align InfoSec with business goals and **enterprise architecture**
- Define desired **security** state based on current risk profile
- Develop a roadmap with security, **physical**, and **operational** architecture



Business Goals and Objectives — emphasizes a critical truth for any CISM-certified professional: **information security must support and enable the organization's business strategy.** It is not just a technical function or a compliance checkbox. It's a core component of enterprise value delivery. At its essence, **corporate governance** is about **directing the enterprise toward strategic goals**, while **managing risk** and **ensuring responsible use of resources**. Within this, **information security governance** exists as a specialized subset — with the same responsibilities, but focused on the confidentiality, integrity, and availability of information assets.

So what does this mean for us as security leaders?

It means that the information security strategy must be built around the **business objectives**. These objectives are typically defined by senior management or the board, and may include goals like:

Entering new markets,
Ensuring uptime for critical systems,
Protecting intellectual property, or
Meeting regulatory mandates.

In this context, information security becomes a **means to an end** — the end being predictable, secure, and efficient achievement of business goals.

Once business outcomes are defined, the **security team must assess the current state** of risk and capability, then develop a plan — a strategy — to bridge the gap between where we are and where we need to be. This is the classic strategic planning model: **assess current state, define desired state, and close the gap.**

That plan should include:

A **conceptual security architecture** integrated with enterprise architecture,

A **logical architecture** (e.g., risk zones, data flows),

And a **physical architecture** involving actual technologies: firewalls, servers, monitoring tools, etc.

Each of these layers must work in tandem. For instance, you cannot design an effective firewall policy unless you understand what data flows are critical and what threats they face.

The strategy must also include:

Defined **security control objectives**,

Metrics to evaluate success,

And **feedback mechanisms** (such as steering committee reviews or quarterly KPI reporting) that allow the strategy to be adjusted over time.

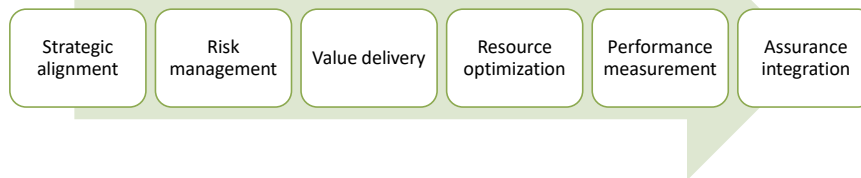
It's worth noting that alignment doesn't just mean "we support the business." It means that security **actively contributes** to business value — whether by reducing risk in mergers and acquisitions, ensuring customer trust, or maintaining regulatory compliance that opens market access.

A successful information security strategy must also respect the organization's **risk appetite** — the level of risk leadership is willing to accept in pursuit of value.

This shapes priorities, budgets, and trade-offs. The CISO's role includes articulating security needs **in business terms** and ensuring that protective measures align with enterprise risk tolerance.

1.5.2 Information Security Strategy Objectives

Align with six governance outcomes



- Identify, value, and classify information assets
- Define goals based on business needs and risk appetite
- Assign ownership and accountability
- Avoid overprotection and misclassification

We're diving into **the objectives of an information security strategy** — and how they must be clearly defined, measurable, and mapped to enterprise priorities. This is not just a checklist — it's about building a strategy that's **effective, efficient, and aligned with business objectives**.

We start with six fundamental governance outcomes that guide the development of strategic objectives. These are:

Strategic alignment – ensuring InfoSec supports business goals

Risk management – mitigating risks to acceptable levels

Value delivery – ensuring InfoSec delivers measurable ROI

Resource optimization – using tools, time, and people wisely

Performance measurement – tracking success through metrics

Assurance process integration – working across silos for holistic protection

But translating these principles into an actionable strategy begins with answering a deceptively simple question:

"What is the actual goal of the security program?"

Many organizations skip this step or assume the answer is obvious: "Protect data." But what does that mean in a large, complex organization with hundreds of applications and terabytes of unstructured data?

The reality is that **most enterprises lack visibility** into their data assets. They

don't know what data they have, who owns it, what value it holds, or where it resides. Without that knowledge, how can we prioritize what to protect?

This leads us to **data valuation and classification**, the foundation of a security strategy. Enterprises must locate and identify their data assets, assign value — often through business impact or process dependency — and classify by sensitivity and criticality. This isn't easy, especially when decades of legacy systems and unused applications have accumulated.

Classification isn't just about putting labels on data; it's about enabling **tiered protection**. For example, public marketing brochures don't need encryption and access controls — but intellectual property or PII absolutely do.

Overclassification is also a risk. In blame-heavy cultures, people tend to overprotect everything, just in case. This wastes resources. A useful solution in some organizations is to **introduce chargeback models** — if storing “critical” data is more expensive, people will be more thoughtful about classification.

Another critical requirement is **ownership**. Every asset must have a defined owner and someone accountable. This is where **RACI matrices** come into play — a tool we discussed earlier. Without clear accountability, protection measures often fall apart in execution.

Ultimately, we can't build a smart, cost-effective security strategy without:

Understanding what needs protection

Knowing how valuable it is

Determining what threats it faces

And aligning our security investments accordingly

The output of this process is a strategy that is **justified, transparent, and actionable** — with measurable objectives and defined success criteria. These objectives are the compass by which the CISO and the enterprise measure progress, justify budgets, and demonstrate value to stakeholders.

1.5.3 Ensuring Objective and Business Integration

- Define a **long-term** desired state of security
- Align security objectives with **business goals**
- Avoid fragmented, **ad hoc security** implementations
- Proactively invest to prevent **costly** incidents
- Security as a **business enabler**, not just **risk mitigation**
- Use **change management**, audit findings, and steering input
- Examples: PKI for trusted transactions, **VPNs** for remote work



This section highlights a **critical principle** for building an effective information security program: ensuring that security objectives are **integrated with business objectives**. The success of any security strategy hinges not just on how well it protects assets, but on how well it supports **business functionality, agility, and resilience**.

To begin, every information security strategy must start by defining **long-term objectives** — these represent the **desired future state** of the enterprise's security posture. Without a clear end state in mind, we risk building disconnected, reactive controls that respond only to the latest incident or compliance need. This lack of integration leads to **ad hoc tactical point solutions**, creating fragmented systems that are difficult and expensive to manage and secure over time.

A common mistake among enterprises is **underinvesting** in proactive information security until a catastrophic breach or incident occurs. History shows us that the cost of response and recovery is often **hundreds of times greater** than the cost of early, strategic investment. A well-documented case is that of a major retailer who suffered a credit card breach — the cost to contain the damage soared into the hundreds of millions of dollars. Ironically, the vulnerabilities exploited were known and could have been mitigated with a

fraction of that cost if addressed early.

Another issue arises when security is viewed **only through the lens of risk mitigation**. While protecting against threats is essential, this limited perspective overlooks a powerful truth: **information security can enable business**.

Let's explore this idea with a few examples:

Deploying a **public key infrastructure (PKI)** can allow secure, verifiable transactions between customers or partners. This isn't just a control — it's an enabler for **new digital services** that require trust.

Implementing **VPNs** for the salesforce doesn't just protect sensitive data in transit — it enables **secure remote work**, contributing to productivity and flexibility.

Enforcing proper **access controls** and **data classification** can help a business pass audits, win contracts, and enter markets that have strict regulatory requirements, such as healthcare or financial services.

Security can also help business units take calculated risks **confidently**. For instance, a business process that would previously be considered "too risky" due to potential data exposure might become viable once proper controls are implemented.

Moreover, the **integration of information security into business planning** helps align budget, compliance, operations, and IT. Business strategy documents, change management logs, audit findings, and steering committee discussions all provide insight into areas where security can **both protect and empower**.

Business Linkages in Information Security Strategy

- Strategic security objectives must **link to business goals**
- Analyze business processes (e.g., **manufacturing, logistics**) for info dependencies
- Failures in **data integrity, availability, confidentiality** can disrupt operations
- InfoSec can prevent disruptions, improve **efficiency, reliability**
- Examples:
 - Entry errors → solved with validation/range checks
 - Instrumentation issues → use redundancy or self-testing
- Linkages enhance InfoSec's **operational value**
- Engage stakeholders via **steering committees & regular meetings**



LevelMentor
Mentorship-Driven Learning

CyberEdge
TECHNOLOGIES

When developing an information security strategy, it's not enough to design high-level governance frameworks or broad risk management practices in isolation. One of the most **critical success factors** is ensuring **business linkages** — that is, direct connections between information security objectives and the **operational and strategic goals** of the business units they support.

Let's illustrate this with a simple but effective example drawn from a manufacturing context — consider a company that produces breakfast cereal. At first glance, it's a physical process: grains are delivered by rail, dumped into hoppers, processed, packaged, and stored. But in reality, this operation is underpinned by a **complex web of data flows and system integrations**. These information systems manage inventory, schedule deliveries, control machinery, track quality, and manage warehouse distribution. If **any link in this information chain breaks down**, the result could be manufacturing downtime, defective product, or supply chain disruptions.

Now think of the classic **CIA triad** — confidentiality, integrity, and availability.

Each of these principles, if compromised, could impact operations:

A **breach of integrity**, such as corrupted or inaccurate data in inventory tracking, could lead to incorrect formulations or production stoppages.

Loss of availability due to a cyber incident or network outage could bring

production to a halt.

While **confidentiality** may not be the primary concern in this use case, a competitor stealing trade secrets or process data could still have a strategic impact.

This is why information security must be embedded into **operational workflows**, not bolted on as an afterthought. Through **process analysis**, we can identify dozens of discrete information points — each representing a potential vulnerability or opportunity for improvement. For instance:

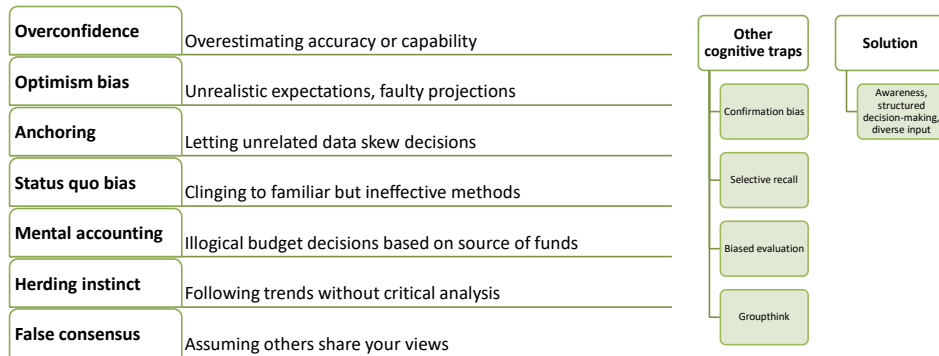
Entry errors could be minimized through technical solutions like range validation or input checks.

Sensor or instrumentation failures might be mitigated through hardware redundancy or scheduled self-tests.

More broadly, these linkages help security teams translate abstract governance goals into **tangible business value**. Security controls, when designed with business processes in mind, don't just mitigate risk — they **improve accuracy, boost productivity, and reduce downtime**.

Equally important is the communication side of security. Security leaders must regularly engage business units to uncover pain points, align priorities, and explain how strategic security investments directly support operational success. A well-functioning **security steering committee** composed of representatives from various departments can facilitate this ongoing dialogue. It can also help security teams advocate for appropriate controls, resources, or technology upgrades while building a **security-aware culture**.

1.5.4 Avoiding Common Pitfalls and Bias



As information security managers work toward developing an effective strategy, it is absolutely vital to recognize and mitigate the influence of **cognitive biases** and **common decision-making pitfalls**. These mental shortcuts and assumptions can derail strategy before it ever takes root, leading to poor investments, missed risks, and misaligned priorities.

Let's start with **overconfidence**, a trait particularly prevalent among professionals with deep experience. People often believe they can estimate risks or outcomes with high precision, even when uncertainty is involved. This leads to dangerously narrow forecasting and poor risk modeling. It's not uncommon for leaders to prefer being "precisely wrong" rather than "vaguely right," which undermines realistic planning.

Optimism bias compounds this issue. Managers naturally want to believe in positive outcomes — that a security program will roll out on time, that risks are minimal, or that attackers will focus on someone else. This leads to under-resourcing and missed contingencies.

A subtle but powerful issue is **anchoring**. If you throw out a number — any number — it can influence decisions that follow, even if completely unrelated. For example, if a previous project cost \$1 million, decision-makers may anchor future project estimates near that figure, regardless of scope differences.

Then there's the **status quo bias** and **endowment effect**. Organizations cling to legacy systems and practices simply because they're familiar, even if they're outdated or inefficient. The discomfort of change often outweighs the logic of innovation. Combined with mental accounting — where people treat money differently based on its origin or category — strategic misalignment can occur. For example, teams might splurge on a “strategic innovation initiative” while starving core maintenance.

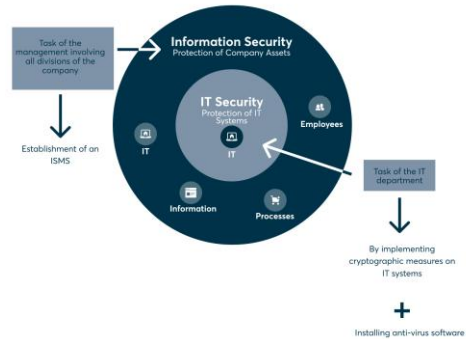
The **herding instinct** is particularly dangerous in cybersecurity. When one organization adopts a hot new trend like blockchain security or identity federation, others often follow without analyzing if it fits their business context. This is strategy based on fear of missing out, not on structured needs assessments.

Another bias that creeps into group discussions is the **false consensus effect** — the assumption that others share your views. It leads to premature agreement and underestimating dissenting risks. This is often coupled with **confirmation bias**, **selective recall**, and **groupthink**, where teams reinforce shared views and dismiss challenges.

So, what can be done? Awareness is the first and most powerful antidote. By acknowledging that these biases exist and actively affect decision-making, security leaders can counteract them. Structured methods such as **risk assessments**, **scenario planning**, and **diverse stakeholder consultations** are key tools. Encouraging dissenting views, using red teams, and seeking third-party validation can prevent flawed consensus and surface hidden issues.

1.5.5 Defining the Desired State of Information Security

- **Desired State** = Future snapshot of security conditions
- Includes:
 - **Principles, policies**, organizational structures
 - **Culture, behavior**, and ethics
 - **Information, infrastructure, skills, applications**
- Defined qualitatively (e.g., **protection** outcomes)
- **COBIT** provides guidance via:
 - Governance system **principles**
 - Governance **framework** principles
- Desired state enables strategy alignment, **integration & compliance**



We explore what it means to define the **"desired state"** of information security for the enterprise — a critical step in shaping a strategic roadmap that aligns business goals with governance, compliance, and operational resilience. The **desired state** refers to a **future point in time** where the organization's information security posture meets clearly defined conditions. It's not just about controls and technology. Instead, it's a **holistic snapshot** that includes principles, policies, organizational structures, behaviors, and competencies — all operating cohesively. To build a realistic and strategic security program, this end-state vision must be well articulated.

Since many security attributes—like resilience, trust, or culture—cannot be measured strictly in numbers, the desired state must often be **qualitatively defined**. For example, rather than stating, “100% system uptime,” we may define success as “high availability of mission-critical systems, with minimal disruption to business processes.” That qualitative definition still allows measurable goals and improvements without getting stuck in false precision.

Let’s now consider how COBIT contributes. COBIT is a **comprehensive governance and management framework** for enterprise IT, and it's extremely helpful in identifying what the desired state should look like for information security. It supports **end-to-end coverage**, meaning it addresses not just IT but

all technology and information processing activities — regardless of where those activities live in the organization.

COBIT introduces **six governance system principles** to help structure and maintain an effective program:

A governance system must balance **value, risk, and resources**.

It must be **holistic**, integrating different types of components.

It should be **dynamic**, able to adapt to changes in the environment or strategy.

It should clearly distinguish between **governance (direction-setting)** and **management (execution)**.

It must be **tailored** using enterprise-specific design factors.

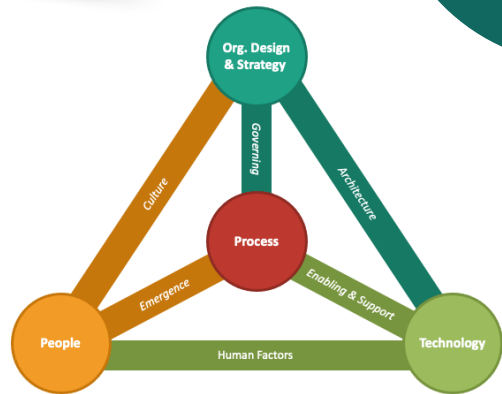
And it must be **enterprise-wide**, covering more than just the IT department.

Additionally, COBIT outlines **three framework principles**, ensuring the model is conceptually sound, flexible, and aligns with existing standards like ISO, NIST, and GDPR.

By using frameworks like COBIT, organizations can define a desired security state that is realistic, adaptable, and aligned with business and regulatory needs. This prevents fragmented approaches and promotes a unified, consistent, and strategic information security posture. The desired state becomes not just a goal — but a **strategic foundation** to ensure alignment, resilience, and value creation in a risk-aware environment.

Business Model for Information Security (BMIS)

- BMIS = Systems-based model for managing security
- Core elements:
 1. **Organization Design & Strategy**
 2. **People**
 3. **Process**
 4. **Technology**
- Six dynamic interconnections link all elements
- Model is adaptive, holistic & reactive to change
- BMIS supports frameworks like COBIT, NIST, ISO



Let's now explore one of the most forward-thinking conceptual frameworks for information security — the **Business Model for Information Security (BMIS)**. This model is crucial for understanding how security functions as an integrated, living system within an enterprise, and it's a powerful complement to technical frameworks like COBIT, ISO, or NIST.

BMIS takes a **systems thinking** approach to information security management. This means it looks beyond isolated controls or departments and considers **how different parts of an organization interact** — sometimes in unexpected and non-obvious ways. It recognizes that security is not just about firewalls and policies; it's about people, behaviors, processes, and how technology and strategy intersect.

At its core, BMIS is structured around **four primary elements**:

Organization Design and Strategy

This defines the enterprise's structure, goals, and business direction. It includes the strategic vision, mission, and how the organization is arranged to fulfill those goals. The security program must align with this direction and evolve alongside it. Culture, architecture, and internal dynamics play a role in shaping the organization's design.

People People are at the heart of any security program — they create, follow, or

sometimes break security processes. BMIS places strong emphasis on HR policies, onboarding, termination, training, and behavioral dynamics. Internally, the model prompts collaboration between security and departments like HR and legal. Externally, customers, vendors, and media can influence the enterprise's security reputation and risk exposure.

Process

This refers to the formal and informal workflows, procedures, and policies that implement the organization's strategy. BMIS insists on documented, adaptable, and business-aligned processes that support confidentiality, integrity, and availability. Well-designed processes provide accountability and form the operational layer of the strategy.

Technology

Technology serves as the enabler of processes and must be considered alongside human behavior. BMIS warns against over-reliance on technical solutions, emphasizing that culture, training, and awareness are equally vital. Security technology must be user-friendly and integrated within the organization's risk appetite and workflow.

A unique aspect of BMIS is its **six dynamic interconnections**, or "tensions," between elements. These are constantly shifting — like push/pull forces that cause the system to adapt. For instance, a change in personnel might trigger policy or technology adjustments, which then affect risk posture. This dynamic interaction makes BMIS an **adaptive model** that can evolve with internal changes or external pressures like cyberattacks or regulation shifts.

The model's **three-dimensional, pyramid-shaped structure** symbolizes its holistic, interconnected nature. If any element is neglected, the equilibrium is disrupted, increasing systemic risk.

Dynamic Interconnections in BMIS

Six Dynamic Interconnections

Governance	Strategic leadership, compliance & adaptability
Culture	Behavior patterns shaping risk perception & action
Enablement & Support	Usable processes aligned with technology
Emergence	Unpredictable patterns & feedback mechanisms
Human Factors	Tech-user interaction, training needs
Architecture	Defense-in-depth, alignment with enterprise design



Now let's focus on one of the most unique and defining features of the Business Model for Information Security (BMIS): the **dynamic interconnections**. These represent the *forces of change* between the four BMIS elements — organization, people, process, and technology. Unlike static frameworks, BMIS recognizes that these elements do not operate in isolation. Instead, they interact through six dynamic forces that **push and pull the model in response to change**.

The **first interconnection** is **Governance**. Governance is not just about setting direction; it's about ensuring compliance, defining boundaries, and enforcing accountability. Within the BMIS model, governance exerts control over how objectives are set and how risk is monitored. It's a feedback mechanism, ensuring processes adapt to performance outcomes and emerging conditions. Poor governance results in disjointed or reactive security programs. Strong governance ensures alignment, consistency, and strategic leadership.

The second interconnection is **Culture**. Culture profoundly affects how risks are perceived and acted upon. It shapes attitudes toward compliance, openness, transparency, and even whistleblowing. Culture exists at multiple levels — national, organizational, and social — and each can affect how security is implemented and received. For example, a hierarchical culture may resist bottom-up feedback, while a collaborative one might welcome it. Understanding

cultural dynamics is key to influencing behavior, achieving policy adoption, and mitigating insider threats.

Third, we have **Enablement and Support**, which connects **processes to technology**. This interconnection reminds us that security must not hinder usability. A well-designed policy or control should support workflows, not disrupt them. For instance, a two-factor authentication method should be secure but also simple enough for users to adopt. This is where policies, standards, and technology intersect — and must be designed to reduce friction and support business agility.

Emergence, the fourth interconnection, refers to **unpredictable, evolving behaviors**. It occurs between people and processes and highlights that enterprises are living systems. Emergent behavior might manifest as a new pattern of insider threats or a user workaround that bypasses controls. Emergence forces us to build adaptive processes, implement continuous feedback loops, and anticipate change in risk management and system design. Next, **Human Factors**. This dynamic addresses the fragile interaction between people and technology. If users don't understand, trust, or properly use technology, then even the best controls can fail. This interconnection explains why training and awareness are not just "nice to have" — they are essential. Errors, misuse, and insider threats are often not malicious but stem from poor understanding or unclear expectations.

Lastly, we have **Architecture** — the dynamic link that ensures all parts of the system are securely and systematically integrated. Enterprise architecture connects technology, people, and process through a defined framework. Security architecture, within this context, ensures that protections are embedded into system design. It's where **defense-in-depth** is planned and implemented across all layers of the organization, enabling consistency, scalability, and cost-efficiency in managing security.

These six dynamic interconnections make BMIS a **living, responsive model**. They reinforce that information security is not a set of controls, but a set of **relationships and reactions**. Neglecting any one interconnection can destabilize the whole system. By understanding and managing these interconnections, security leaders can maintain equilibrium and adapt to constant change.

Governance, Risk Management & Compliance (GRC)

Integrating Assurance for Security and Performance

Governance	Board & senior management oversight; policy creation
Risk Management	Identify, assess, mitigate risk to business objectives
Compliance	Monitor and enforce adherence to standards & regulations
Integration	GRC convergence improves efficiency, reduces silos
GRC Tools	Support financial, IT, and legal governance needs



Let's now dive into an essential concept in enterprise assurance and security: **Governance, Risk Management, and Compliance — commonly known as GRC**. GRC is more than just a buzzword; it is a strategic, integrated approach that helps organizations align business activities with regulatory requirements, manage risks efficiently, and ensure oversight by top leadership. As security threats grow more complex and regulatory environments become more demanding, **GRC is increasingly recognized as a necessary component of sustainable, secure operations**.

First, **Governance** refers to the structures, rules, and decision-making processes created and overseen by senior management and the board of directors. It defines how authority is exercised, how decisions are made, and how policies are enforced. Governance establishes the expectations and accountability framework that employees must operate within. Without effective governance, even the best technical controls can be rendered useless due to lack of enforcement or organizational direction.

Risk Management, the second component, is the systematic process of identifying potential threats and vulnerabilities that could impact the organization's ability to achieve its objectives. It involves assessing the likelihood and impact of risks, prioritizing them based on business relevance, and

implementing controls to mitigate them. In the context of information security, this might include identifying risks to data confidentiality, system availability, or regulatory noncompliance. Risk management is not about eliminating all risk—it's about **maintaining risk within acceptable thresholds** as defined by the enterprise's risk appetite.

The third pillar, **Compliance**, is about ensuring that all policies, laws, regulations, and standards are followed. It's the monitoring and documentation side of assurance—making sure that what is written in policies is actually reflected in behavior and process execution. For example, a policy may require annual password changes or data encryption at rest; compliance mechanisms verify whether these practices are being followed.

Now, the reason GRC is usually grouped as a single initiative is because **all three elements are interconnected**. Governance drives policy. Risk management aligns controls to business priorities. Compliance monitors whether those controls are effective. If treated separately, these functions can create silos, inefficiencies, and even contradictory practices. **GRC convergence**, or the integration of these assurance activities, brings consistency, eliminates redundancy, and improves visibility across the enterprise.

A fully integrated GRC strategy helps ensure that **information security supports business performance and resilience**. It ensures that financial systems are properly controlled, IT systems are secure and aligned with policy, and legal obligations are met with documented evidence. Today, many organizations use **GRC platforms**—software tools that centralize documentation, risk assessment, policy enforcement, and audit readiness. These tools provide dashboards for visibility, automate compliance tracking, and streamline risk mitigation efforts.

1.5.6 Information Security Strategy Development

- Define current vs. desired **security state**
- Develop a **road map** to bridge the gap
- Align with business **goals & risk tolerance**
- Go beyond **controls** consider process redesign
- Balance security with **operational** efficiency
- Ensure strategy supports legal and **regulatory** compliance
- Goal: Business **process** assurance at acceptable **cost**



Developing an **information security strategy** is a foundational step in transforming an enterprise's security posture from its current state to a **well-defined desired state**. This process is strategic, structured, and deeply aligned with the broader goals of the business. Let's walk through what that really involves.

First, strategy development begins with a clear understanding of **where the organization stands today in terms of security maturity**, and where it **needs to go**. This gap analysis provides the groundwork for creating a **road map**, which serves as a navigational guide for security improvement initiatives.

A strong strategy is not just a list of controls—it is a **comprehensive plan** designed to support business operations by managing risk, enabling compliance, and ensuring continuity. It must be **anchored in the organization's specific risk appetite**, legal and regulatory requirements, and operational priorities.

It's a common misstep to think of strategy as merely deploying more controls. While controls like firewalls, encryption, or access management are important, they are not always the best—or only—solution. For example, **reengineering a flawed process** can sometimes reduce or eliminate risk more effectively than a technical control. This is especially true when controls interfere with efficiency or

productivity. Remember, **security should not cripple the business**; it should **enable it**.

That's why every mitigation decision must be weighed with a **cost-benefit analysis**. Is the security solution worth the operational trade-off? Does it align with productivity goals? Can the same result be achieved with less complexity or cost? These are critical questions that strategy developers must continuously ask.

In designing the strategy, we also must recognize that the ultimate goal of security isn't about locking everything down. Rather, it is to provide **assurance that business processes will function as intended, with minimal disruptions and at an acceptable cost**. That is the essence of business process assurance—keeping the wheels of the organization turning even in the face of risk.

This applies to all sectors, whether it's a private enterprise focused on shareholder value or a government agency delivering public services. **Protecting the assets that support critical services, maintaining trust, and minimizing operational disruptions** is what defines a successful security strategy.

To wrap up, a good security strategy is about:

Vision: knowing where you want to go,

Intelligence: understanding how to get there efficiently,

Balance: optimizing risk and value,

Execution: aligning resources, people, and processes.

1.5.7 Elements of a Strategy

- Define **resources** and identify **constraints**
- Develop a **road map** with people, processes, and technologies
- Leverage **enterprise security architecture**
- Break strategy into **short-term tactical projects**
- Align short-term wins with **long-term objectives**
- Monitor progress using **defined metrics and checkpoints**
- Build supporting **policies and standards**



We move from the abstract concepts of vision and alignment into the **tactical framework** that brings an information security strategy to life. We ask a fundamental question: **What elements must be included in a security strategy for it to be effective, sustainable, and business-aligned?**

To begin, a well-formulated strategy must consider both **resources and constraints**. Resources may include technologies, skilled personnel, supporting processes, and the enterprise's budget. Constraints often involve legacy systems, compliance requirements, organizational resistance, and timeframes set by business cycles.

The strategy is not a one-time project; it's a **long-term transformation roadmap**. This road map should clearly outline the series of actions—people, processes, and technologies—needed to reach the enterprise's desired security state. These are not abstract ideas but **concrete, manageable projects** aligned with defined goals.

This is where **enterprise security architecture** comes into play. It offers structure. It allows us to define how business drivers, processes, and IT systems intersect with security requirements. Incorporating architecture thinking into strategy ensures that we're not simply responding to threats but building systems with resilience and **security by design**.

Next, we must acknowledge that this journey is resource-intensive. A common pitfall is trying to tackle everything at once. Instead, the strategy should be divided into **short-term, achievable projects**. These smaller milestones help deliver **early wins**, validate the direction of the strategy, and provide flexibility to adjust course when needed.

For instance, suppose the enterprise has a long-term goal of **data classification by sensitivity and criticality**. For a large organization, this can take years.

Instead of attempting to classify everything at once, the strategy might aim for **25% completion per year**. Alongside this, implementing policies that prevent further uncontrolled data accumulation ensures the problem doesn't worsen during the remediation process.

These **short-term objectives** serve as both **checkpoints and performance indicators**. Through clearly defined **metrics and monitoring**, they provide insight into whether the overall strategy is on track. Mid-course corrections can then be made without derailing the entire program.

Finally, to support the strategy's execution, **policies and standards** must be developed in parallel. These serve as the governance layer that ensures consistency, accountability, and direction across all security initiatives.

To sum up, the key to a successful information security strategy is to:

Break down complexity into manageable parts,

Align daily actions with long-term vision,

And use architectural thinking to ensure alignment and sustainability.

This is not just a plan—it's a **living roadmap** toward enterprise resilience.

Resources and Constraints Overview

- Governed by COBIT's governance system components
- Resources and constraints must be evaluated **holistically**
- Governance components:
 - o Principles, Policies & Frameworks
 - o Processes
 - o Organizational Structures
 - o Culture, Ethics & Behavior
 - o Information
 - o Services, Infrastructure & Applications
 - o People, Skills & Competencies
- These components can act as **enablers or barriers**



Every strategic effort, especially in the complex field of information security, depends on a set of internal and external factors. These can either **enable success** or become **barriers** that hinder progress. COBIT, a globally recognized framework for governance and management of enterprise IT, defines a governance system through seven integrated components. These components are no longer referred to as enablers exclusively—they're more appropriately described as both **resources and constraints**, depending on how they are managed.

Let's begin with the **Principles, Policies, and Frameworks**. These serve as the **guidance system** for behavior and operations across the enterprise. Well-defined policies promote consistency and accountability, but overly rigid or outdated policies can restrict innovation and delay action.

Second, we have **Processes**—the organized sets of practices and activities that drive day-to-day operations. Processes must be streamlined, relevant, and adaptable. However, overly bureaucratic or inefficient processes can become roadblocks, especially during incident response or change management.

Organizational Structures—the decision-making hierarchy—also shape how agile or responsive a security program can be. If roles and responsibilities are clearly defined and delegated, the structure serves as a powerful enabler. But

ambiguity or centralized bottlenecks in decision-making can slow down progress and lead to oversight failures.

Another powerful factor is **Culture, Ethics, and Behavior**. While often overlooked, culture can either reinforce compliance or sabotage controls through informal “workarounds.” A culture that values ethics, security awareness, and accountability will naturally support governance. However, if the culture resists change or lacks awareness, even the most sophisticated tools may fail.

Then there’s **Information**, the lifeblood of modern enterprises. Information must be classified, accurate, and accessible to support governance. But information overload, poor data quality, or lack of ownership can quickly become strategic constraints.

Services, Infrastructure, and Applications represent the technical foundation. They are necessary to automate and secure business functions, but aging or poorly integrated systems can undermine strategy. Technical debt is a major constraint that must be accounted for during planning.

Lastly, we address **People, Skills, and Competencies**. No strategy is executable without qualified personnel. Whether it's hiring internal talent or bringing in external consultants, the lack of appropriate expertise is one of the most common—and expensive—strategic constraints.

It is essential to recognize that **each of these components exists in duality**.

They can either fuel strategy or impede it. The role of the information security manager is to **evaluate each one both as a potential resource and as a constraint**, then plan accordingly. If, for example, organizational culture is resistant to change, then additional effort must go into awareness and training campaigns.

Resources in Information Security Strategy

- Maximize use of existing assets and capabilities
- Types of resources:
 - **Policies, Standards, Procedures, Guidelines**
 - **Architectures** and layered defenses
 - **Controls**: physical, technical, procedural
 - **Technologies** and countermeasures
 - **Human resources**: roles, skills, training
 - **Risk tools**: BIA, risk analysis, threat/vulnerability assessment
 - **Audits, compliance, third-party support**
 - Facilities & environmental security



As we continue our development of an effective information security strategy, one of the most critical areas to address is understanding and leveraging the **available resources**. This is more than just budget—it's a full inventory of **mechanisms, people, processes, tools, and support systems** that can be utilized to achieve and maintain the desired state of security.

First, it's important to emphasize that **the strategy should not reinvent the wheel**. Wherever possible, we aim to **maximize existing capabilities and infrastructure**. This approach is cost-effective, accelerates implementation, and aligns with established organizational practices.

Let's begin with foundational elements: **policies, standards, procedures, and guidelines**. These are the governance tools that define the rules and expectations. Policies set the direction, standards ensure consistency, procedures define execution, and guidelines offer flexibility. A mature organization will already have many of these in place, and aligning the security strategy with them ensures consistency and support.

Security architectures play a significant role in planning and implementing defenses. These may include frameworks for network segmentation, identity management, or data classification models. Layered defenses—often described as "defense in depth"—involve physical, technical, and procedural **controls** that

work together to protect critical assets. Think of firewalls, access badges, CCTV, encryption, multi-factor authentication, and separation of duties.

Technology is another massive resource category. These include security solutions such as SIEM (Security Information and Event Management) systems, endpoint protection tools, data loss prevention (DLP), and patch management solutions. It's also important to evaluate which existing IT tools can be repurposed or enhanced for better security outcomes.

Human capital is arguably the most critical resource. This includes the **organizational structure**, defined **roles and responsibilities**, and the **skills and competencies** of personnel. We must also factor in **training, awareness, and education** programs to build and maintain a security-conscious culture across all levels of the enterprise.

Another vital group of resources are **analytical tools** that support informed decision-making. These include **threat and vulnerability assessments**, **business impact analysis (BIA)**, **risk analysis**, and **resource dependency analysis**. These tools help security leaders understand what's most at risk and prioritize accordingly.

Let's not overlook **compliance and audit functions**, which validate adherence to policies and help identify gaps. Partnerships with **third-party vendors** or managed service providers can also extend your resource pool—often offering specialized capabilities at lower costs than internal development.

Constraints in Information Security Strategy

Identifying and Managing Strategic Constraints

- Constraints to consider when building strategy:

Legal and regulator	Obligations
Physical	Environmental limitations
Ethical	Boundaries and social expectations
Costs	Time, budget, opportunity
Personnel	Resistance and fatigue
Decision-making	Structure and silos
Resource limitations	Capital, skills, tech
Capabilities	Knowledge and expertise gaps
Time	Pressures and mandated deadlines
Risk	Appetite and enterprise tolerance
Organizational culture,	Internal and external



In developing an information security strategy, it is just as important to understand your **constraints** as it is to know your available resources. Constraints serve as the boundaries within which your strategy must operate. They are not just obstacles—they are real-world considerations that inform what is **practical, sustainable, and achievable**.

Let's begin with **legal and regulatory constraints**. These are non-negotiables. Every enterprise must operate within the framework of applicable laws—such as data protection regulations, industry-specific mandates, or contractual obligations. Failure to comply can result in significant financial penalties, reputational damage, or even legal action.

Physical constraints include things like limited data center space, outdated building infrastructure, or even environmental risks such as location-specific hazards. These factors can restrict implementation options, such as the ability to scale up on-premises resources or deploy sensitive infrastructure in certain geographic zones.

Ethical constraints involve what is considered appropriate and justifiable in both industry and society. For instance, surveillance practices may be legal in some jurisdictions but deemed unethical by stakeholders or the public. Security must not come at the cost of eroding trust.

Culture, both organizational and societal, plays a powerful role in shaping what will be accepted and adopted. For example, in a highly decentralized enterprise, trying to implement centralized security controls might be met with resistance. Externally, certain regions or cultures may have different expectations about privacy, autonomy, or compliance—these must be respected and factored in.

Cost is a universal constraint—this includes time, budget, and opportunity cost. The enterprise may have many priorities competing for limited financial and human capital. A strong strategy recognizes these limits and aims to **prioritize risk mitigation efforts that deliver the highest value for cost**.

Human factors like **personnel resistance** are also crucial. Change is hard, and new controls, procedures, or oversight may be met with suspicion or resentment. Strategy developers must anticipate this and integrate change management and awareness programs to mitigate it.

Organizational structure may create silos or unclear lines of authority, complicating cross-functional collaboration. It's essential to map out how decisions are made and who must be involved in approving or executing each part of the strategy.

Resource and capability gaps—for example, a lack of security architects or trained personnel—may require outsourcing, upskilling, or revised timelines. Time is another critical constraint. Some security improvements are tied to **compliance deadlines** or **project delivery windows**. Others may require action within a limited threat exposure window.